

Third-Party Vendor Risk Assessment — Salesforce CRM Platform

Domain: GRC | Third-Party Risk Management | Vendor Risk Assessment

Frameworks: FedRAMP | CMMC 2.0 | NIST SP 800-171 | NIST SP 800-53 | DoD IL4/IL5 | SOC 2

Vendor Assessed: Salesforce, Inc. (trust.salesforce.com)

Fictional Organization: Apex Defense Solutions (Government Contractor)

Difficulty: Intermediate

Date Completed: May 19, 2026

Project Overview

This project presents a formal Third-Party Vendor Risk Assessment (TPRM) of Salesforce as a CRM platform candidate for Apex Defense Solutions, a fictional government contractor subject to FedRAMP, CMMC 2.0, and NIST SP 800-171 requirements.

The assessment was conducted entirely through publicly available documentation on Salesforce's trust center (trust.salesforce.com) the same methodology used by GRC analysts conducting vendor due diligence in real enterprise environments. No vendor access, no questionnaire responses, no proprietary data was used. All findings are based on Salesforce's publicly published compliance certifications, security attestations, and availability documentation.

The report is written for a CISO audience and follows the structure of a formal procurement risk assessment inherent risk scoring, residual risk scoring, compliance certification mapping, gap identification, and a formal Accept/Reject/Accept with Conditions recommendation with specific contractual prerequisites.

Scenario Context

Assessing Organization: Apex Defense Solutions, a fictional mid-size government contractor providing systems integration, cybersecurity consulting, and program management services to federal defense and intelligence agencies. Holds active DoD contracts and processes Controlled Unclassified Information (CUI).

Procurement Decision: Evaluating Salesforce CRM to manage customer relationships, contract pipelines, and stakeholder communications. Potential CUI flow through the CRM elevates this from a standard SaaS review to a government-sensitive procurement decision.

Applicable Obligations: FedRAMP authorization requirements, CMMC 2.0 Level 2 certification, NIST SP 800-171 CUI protection, and DoD IL4 data handling standards.

Assessment Methodology

The assessment evaluated Salesforce across five research areas:

1. Compliance Certification Review Mapped all active Salesforce certifications to the applicable government contractor compliance framework. Identified confirmed certifications, gaps, and items requiring contractual clarification. Reviewed both Government/Defense certifications and Security/Privacy certifications separately.

2. Risk Domain Scoring Scored Salesforce across 10 risk domains on a 1-10 scale (10 = lowest risk) using publicly available evidence:

Risk Domain	Score	Key Factor
Access Controls & IAM	9/10	FedRAMP High 3PAO-validated controls
Data Encryption	9/10	FIPS 140-2 validated required by FedRAMP
Vulnerability Management	9/10	Active pen testing updated May 19, 2026
Data Residency & Sovereignty	8/10	Hyperforce US region available must be configured
Incident Response	8/10	NIST 800-61 compliant per FedRAMP SLAs not public
Business Continuity & DR	8/10	ISO 22301 certified RTO/RPO requires contract
Privacy & Data Protection	8/10	ISO 27018, GDPR, BCRs in place

Risk Domain	Score	Key Factor
Third-Party / Supply Chain	7/10	Extensive sub-processor ecosystem - review required
Availability & SLA	6/10	SLA percentages not publicly disclosed
CMMC 2.0 Alignment	6/10	Not explicitly confirmed - requires clarification

3. Inherent Risk Assessment Evaluated risk before considering controls data sensitivity, vendor access level, business criticality, and regulatory exposure. Overall inherent risk: **HIGH** due to potential CUI processing in a SaaS environment under government contractor obligations.

4. Residual Risk Assessment Evaluated remaining risk after applying Salesforce's documented controls. FedRAMP High, DoD IL4/IL5, NIST 800-171, and SOC 2 Type II collectively reduce inherent risk to **LOW-MEDIUM**.

5. Gap Identification Identified items confirmed on trust center vs. items requiring contractual clarification or direct vendor engagement.

Key Findings

Positive Findings

- **FedRAMP High Authorization** — highest federal authorization level, exceeding the FedRAMP Moderate baseline required for most government contractor use cases
- **DoD IL4 and IL5 Authorization** — directly covers CUI handling requirements applicable to defense contractors
- **NIST SP 800-171 Compliance** — foundational framework for CMMC 2.0 Level 2, substantially addresses contractor CUI protection obligations
- **SOC 2 Type II** — independent sustained-period audit of security controls across Security, Availability, Integrity, Confidentiality, and Privacy
- **Active Third-Party Penetration Testing** — results current as of May 19, 2026, demonstrating ongoing validation rather than point-in-time compliance
- **Hyperforce US Data Residency** — US-only data center option available for contracts requiring geographic data restrictions

- **476 Active Compliance Documents** — exceptional documentation maturity compared to typical SaaS vendors

Gaps Identified

- **CMMC 2.0 Formal Certification** — not explicitly confirmed on trust center despite strong NIST 800-171 and DoD IL4 posture
 - **Uptime SLA Commitments** — not publicly disclosed, requires contractual negotiation
 - **SOC 2 Full Report** — requires NDA to access, must be reviewed for exceptions before CUI authorization
 - **Sub-Processor Inventory** — complete list requires review to assess downstream vendor risk
 - **Data Processing Agreement** — must be negotiated specifically for CUI handling obligations
-

Recommendation

ACCEPT WITH CONDITIONS

Salesforce is recommended for conditional approval subject to six mandatory prerequisites before CUI data onboarding:

1. Written confirmation of CMMC 2.0 Level 2 certification status or documented compliance roadmap
 2. SOC 2 Type II full report review under NDA, no qualified opinions acceptable for CUI authorization
 3. Contractually bound SLA commitments (99.9% uptime minimum, RTO ≤4 hours, RPO ≤1 hour, breach notification ≤72 hours)
 4. Executed Data Processing Agreement addressing CUI obligations, data residency, and breach notification
 5. Written confirmation of Hyperforce US region configuration for all Apex Defense Solutions data
 6. Annual reassessment scheduled to verify continued certification currency
-

Skills Demonstrated

- Third-party risk management (TPRM) methodology applied to a government-sensitive procurement

- Compliance framework mapping — FedRAMP, CMMC 2.0, NIST SP 800-171, DoD IL, SOC 2, ISO 27001
 - Inherent vs. residual risk scoring with supporting evidence
 - Gap analysis — identifying what's confirmed vs. what requires contractual resolution
 - Government contractor risk context — CUI handling, federal authorization requirements, geopolitical data residency
 - Executive risk communication — translating compliance documentation into a CISO-level recommendation
 - Vendor due diligence using only publicly available information (trust center methodology)
-

Repository Structure

salesforce-vendor-risk-assessment/

|

|— README.md ← This file

|— Bryan_Sykes_Vendor_Risk_Assessment_Salesforce.docx ← Full assessment report

|

|— screenshots/

|— 01-salesforce-compliance-categories.png

|— 02-salesforce-compliance-categories-2.png

|— 03-salesforce-compliance-documents.png

|— 04-salesforce-availability-page.png

Notes

- This is a portfolio project — Apex Defense Solutions is a fictional organization
- All Salesforce compliance data sourced from publicly available trust.salesforce.com documentation
- Assessment reflects information available as of May 19, 2026

- No proprietary Salesforce documentation, NDA-protected reports, or non-public data was accessed or used
 - The CMMC gap finding reflects the state of publicly available documentation — Salesforce may hold CMMC certifications not yet reflected on the public trust center
-

Part of an ongoing cybersecurity portfolio. Additional projects cover AWS GuardDuty cloud threat detection, AI model supply chain risk assessment, OWASP Top 10 web application exploitation, Security Onion SIEM detection engineering, and NIST CSF framework assessments.